



Figure 5 - Tools: Exploit



Figure 6 - Damn Vulnerable Web Application

the login screen (Figure 1). The username and password are 'samurai'; use these to log in and get to the desktop (Figure 2).

As mentioned earlier, Samurai comes with a bundle of pen-testing tools (see Figures 3, 4 and 5). In the following sections, I will demonstrate the four stages of Web application pen-testing, using one tool from each category. As you will notice, Samurai has clubbed Reconnaissance and Mapping into one application category. Let's begin with those two stages.

Introducing DVWA

Let's use a test-bed to understand the four stages in their entirety. Samurai bundles a neat Web application that runs on PHP/MySQL, called DVWA—Damn Vulnerable Web App (Figure 6). This is a Web application which is, well, damn vulnerable. It's got a lot of loopholes, and is meant to help you understand pen-testing; so let's use this to understand the concepts of pen-testing. You can access DVWA by opening Firefox in Samurai, and navigating to <http://dvwa/>. Alternatively, you can access it via the Samurai local home page (<http://localhost/>)

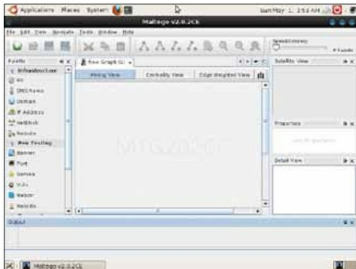


Figure 7 - Maltego main screen

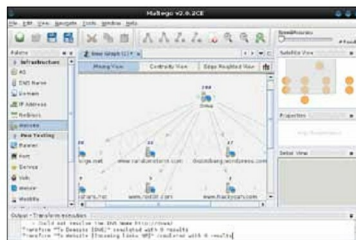


Figure 8 - Maltego map

Reconnaissance and mapping

For reconnaissance and mapping, use the ever-powerful Maltego (Community Edition), for example, if you want to see all the 'To Websites' entries for the domain <http://dvwa/> (which is our DVWA address). First, start Maltego (see Figure 7) and drag the 'Website' node onto the graph. Click the node, and edit the Value property in the Properties editor on the right; set it to <http://dvwa/>. Now right-click the node, and select *Incoming Links > All In This Set*. This will draw up a map of the incoming links to your Web applications (Figure 8). Similarly, you can recon and map various entities available in the Maltego toolbox.

Discovery

W3af, the Web Application Attack and Audit Framework, is a very powerful utility for running a discovery on a URL. It's intuitive and fast. Start the w3af GUI from *Applications > Samurai > Discovery > w3af GUI*. In the URL field, enter <http://dvwa/>. Generally, you select the plug-ins that you want to use to test; for now, just select *fast_scan* to run a quick scan, and click the 'Start' button on the top toolbar (see Figure 9). The scan begins to run, and soon you will get an SQL injection